

Scenario 1 – Login & Authentication Flow

Owner: Ananth Chowdary Ramineni
Reviewer: BTH Master's Thesis
Contributors:
Date Generated: Wed Aug 19 2026

Executive Summary

High level system description

Web-based authentication system allowing users to register, log in, authenticate through a backend authentication server, validate credentials against a user database, generate session tokens, and access a protected dashboard through a dedicated session management module.

Summary

Total Threats	38
Total Mitigated	0
Total Open	38
Open / Critical Severity	0
Open / High Severity	0
Open / Medium Severity	0
Open / Low Severity	0
Open / TBD Severity	38

Login & Authentication Flow

EE1 End User (Actor)

Description: External user interacting with the authentication system through a web browser.

Number	Title	Type	Severity	Status	Score	Description	Mitigations
1	CAPTCHA defeat	Elevation of privilege	TBD	Open		See OWASP Automated Threat #9: Automation is used in an attempt to analyse and determination the answers to CAPTCHA tests and related puzzles	Defences include guarding against automation, unguessable CAPTCHA and proper enforcement of behavioral workflow
2	Credential stuffing	Information disclosure	TBD	Open		See OWASP Automated Threat #8: Lists of stolen authentication credentials are tested against the application’s authentication mechanisms to identify whether users have re-used the same login credentials	Defences against Credential Stuffing are described in the OWASP Credential Stuffing Prevention Cheat Sheet, Multi-Factor Authentication being a primary counter-measure

P1 Web Frontend Interface (Process)

Description: Public application interface receiving user registration, login requests, authenticated requests and chatbot interactions.

Number	Title	Type	Severity	Status	Score	Description	Mitigations
7	Least privilege	Elevation of privilege	TBD	Open		If a process is comprimised and under control of a malicious actor, horizontal/lateral elevation of privilege can be used to compromise other processes	Processes should run with least privilege that is practical, to minimise the impact of horizontal elevation of privilege
8	Expedition	Tampering	TBD	Open		See OWASP Automated Threat #6: Using speed to violate explicit or implicit assumptions about the application’s normal use to achieve unfair individual gain	Defences include providing enforcement of behavioral workflow and anti-automation
9	Vulnerability scanning	Information disclosure	TBD	Open		See OWASP Automated Threat #14: Systematic enumeration and examination in order to find weaknesses and points where a security vulnerability might exist	Defence includes providing anti-automation
10	Denial of Service	Elevation of privilege	TBD	Open		See OWASP Automated Threat #15: Usage may resemble legitimate application usage but leads to exhaustion of resources	Mitigation or prevention such as providing backoff, resource management and avoiding forced deadlock
11	Footprinting	Information disclosure	TBD	Open		See OWASP Automated Threat #18: Information gathering with the objective of learning as much as possible about the composition, configuration and security mechanisms of the application	Defences include shutting down unnecessary services/ports and excluding information that could identify and compromise security of the organisation

P2 Authentication Service (Process)

Description: Trusted backend service responsible for registration, login validation, authentication decisions, and session creation requests.

Number	Title	Type	Severity	Status	Score	Description	Mitigations
14	Least privilege	Elevation of privilege	TBD	Open		If a process is comprimised and under control of a malicious actor, horizontal/lateral elevation of privilege can be used to compromise other processes	Processes should run with least privilege that is practical, to minimise the impact of horizontal elevation of privilege

Number	Title	Type	Severity	Status	Score	Description	Mitigations
15	Expedition	Tampering	TBD	Open		See OWASP Automated Threat #6: Using speed to violate explicit or implicit assumptions about the application’s normal use to achieve unfair individual gain	Defences include providing enforcement of behavioral workflow and anti-automation
16	Vulnerability scanning	Information disclosure	TBD	Open		See OWASP Automated Threat #14: Systematic enumeration and examination in order to find weaknesses and points where a security vulnerability might exist	Defence includes providing anti-automation
17	Denial of Service	Elevation of privilege	TBD	Open		See OWASP Automated Threat #15: Usage may resemble legitimate application usage but leads to exhaustion of resources	Mitigation or prevention such as providing backoff, resource management and avoiding forced deadlock
18	Footprinting	Information disclosure	TBD	Open		See OWASP Automated Threat #18: Information gathering with the objective of learning as much as possible about the composition, configuration and security mechanisms of the application	Defences include shutting down unnecessary services/ports and excluding information that could identify and compromise security of the organisation

P3 Session Management Module (Process)

Description: Creates, stores, retrieves and validates authenticated sessions. Session tokens are never shared with AI components.

Number	Title	Type	Severity	Status	Score	Description	Mitigations
20	Least privilege	Elevation of privilege	TBD	Open		If a process is comprimised and under control of a malicious actor, horizontal/lateral elevation of privilege can be used to compromise other processes	Processes should run with least privilege that is practical, to minimise the impact of horizontal elevation of privilege
21	Expedition	Tampering	TBD	Open		See OWASP Automated Threat #6: Using speed to violate explicit or implicit assumptions about the application’s normal use to achieve unfair individual gain	Defences include providing enforcement of behavioral workflow and anti-automation
22	Vulnerability scanning	Information disclosure	TBD	Open		See OWASP Automated Threat #14: Systematic enumeration and examination in order to find weaknesses and points where a security vulnerability might exist	Defence includes providing anti-automation
23	Denial of Service	Elevation of privilege	TBD	Open		See OWASP Automated Threat #15: Usage may resemble legitimate application usage but leads to exhaustion of resources	Mitigation or prevention such as providing backoff, resource management and avoiding forced deadlock
24	Footprinting	Information disclosure	TBD	Open		See OWASP Automated Threat #18: Information gathering with the objective of learning as much as possible about the composition, configuration and security mechanisms of the application	Defences include shutting down unnecessary services/ports and excluding information that could identify and compromise security of the organisation

Registration/Login Credentials (Data Flow)

Description: User submits login credentials through the browser.

Number	Title	Type	Severity	Status	Score	Description	Mitigations
3	Vulnerable transport protocol	Information disclosure	TBD	Open		Older transport protocols are vulnerable and have known vulnerabilities	Use up to date cryptography and transport protocols
4	Fingerprinting	Information disclosure	TBD	Open		See OWASP Automated Threat #4: Specific requests are sent to the application eliciting information in order to profile the application	Defence includes restricting what information is provided, for example version numbers and package details

Credential Submission (Data Flow)

Description: Web frontend forwards user credentials for authentication.

Number	Title	Type	Severity	Status	Score	Description	Mitigations
12	Vulnerable transport protocol	Information disclosure	TBD	Open		Older transport protocols are vulnerable and have known vulnerabilities	Use up to date cryptography and transport protocols

Session Creation Request (Data Flow)

Description: Authentication server requests generation or validation of a session token.

Number	Title	Type	Severity	Status	Score	Description	Mitigations
19	Vulnerable transport protocol	Information disclosure	TBD	Open		Older transport protocols are vulnerable and have known vulnerabilities	Use up to date cryptography and transport protocols

Authenticated Dashboard Request (Data Flow)

Description: User accesses protected resources using a valid session token.

Number	Title	Type	Severity	Status	Score	Description	Mitigations
5	Vulnerable transport protocol	Information disclosure	TBD	Open		Older transport protocols are vulnerable and have known vulnerabilities	Use up to date cryptography and transport protocols
6	Fingerprinting	Information disclosure	TBD	Open		See OWASP Automated Threat #4: Specific requests are sent to the application eliciting information in order to profile the application	Defence includes restricting what information is provided, for example version numbers and package details

Credential Verification Query (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
--------	-------	------	----------	--------	-------	-------------	-------------

Authentication Verification Result (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
--------	-------	------	----------	--------	-------	-------------	-------------

Session Lookup (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
--------	-------	------	----------	--------	-------	-------------	-------------

Session Validation Result (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
--------	-------	------	----------	--------	-------	-------------	-------------

Approved Context Query (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
--------	-------	------	----------	--------	-------	-------------	-------------

Approved Context Data (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
--------	-------	------	----------	--------	-------	-------------	-------------

Session Token (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
--------	-------	------	----------	--------	-------	-------------	-------------

Authentication Result (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
--------	-------	------	----------	--------	-------	-------------	-------------

Chatbot Question (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
--------	-------	------	----------	--------	-------	-------------	-------------

Chatbot Answer (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
--------	-------	------	----------	--------	-------	-------------	-------------

Generated LLM Response (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
--------	-------	------	----------	--------	-------	-------------	-------------

Prompt Request (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
--------	-------	------	----------	--------	-------	-------------	-------------

Processed AI Response (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
--------	-------	------	----------	--------	-------	-------------	-------------

Prompt + Approved Context (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
--------	-------	------	----------	--------	-------	-------------	-------------

P4 AI chatbot Component (Process)

Description: AI assistant handling user questions related to authentication. It receives untrusted user prompts, validates user context, retrieves approved information, and sends controlled requests to the LLM integration service.

Number	Title	Type	Severity	Status	Score	Description	Mitigations
58	Expedition	Tampering	TBD	Open		See OWASP Automated Threat #6: Using speed to violate explicit or implicit assumptions about the application’s normal use to achieve unfair individual gain	Defences include providing enforcement of behavioral workflow and anti-automation
59	Vulnerability scanning	Information disclosure	TBD	Open		See OWASP Automated Threat #14: Systematic enumeration and examination in order to find weaknesses and points where a security vulnerability might exist	Defence includes providing anti-automation
60	Denial of Service	Elevation of privilege	TBD	Open		See OWASP Automated Threat #15: Usage may resemble legitimate application usage but leads to exhaustion of resources	Mitigation or prevention such as providing backoff, resource management and avoiding forced deadlock

P5 LLM Integration Service (Process)

Description: Service responsible for communicating with the external LLM provider. It filters data before transmission and ensures no credentials, hashes, session tokens or API keys leave the application.

Number	Title	Type	Severity	Status	Score	Description	Mitigations
46	Expedition	Tampering	TBD	Open		See OWASP Automated Threat #6: Using speed to violate explicit or implicit assumptions about the application’s normal use to achieve unfair individual gain	Defences include providing enforcement of behavioral workflow and anti-automation
47	Vulnerability scanning	Information disclosure	TBD	Open		See OWASP Automated Threat #14: Systematic enumeration and examination in order to find weaknesses and points where a security vulnerability might exist	Defence includes providing anti-automation
48	Denial of Service	Elevation of privilege	TBD	Open		See OWASP Automated Threat #15: Usage may resemble legitimate application usage but leads to exhaustion of resources	Mitigation or prevention such as providing backoff, resource management and avoiding forced deadlock

EE2 External LLM Provider (Actor)

Description: Outside application security control

Number	Title	Type	Severity	Status	Score	Description	Mitigations
--------	-------	------	----------	--------	-------	-------------	-------------

DS1 User Database (Store)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
52	Scraping	Information disclosure	TBD	Open		See OWASP Automated Threat #11: Collecting accessible data and/or processed output from the application	Detect fake or compromised accounts, ensure information is accessible only with authentication and authorisation
53	Skewing	Elevation of privilege	TBD	Open		See OWASP Automated Threat #16: Automated repeated clicking or requesting or submitting content, affecting application based metrics such as counts, and measures of frequency and/or rate	Defences include control of interaction frequency or proper enforcement of a single unique action
54	Spamming	Elevation of privilege	TBD	Open		See OWASP Automated Threat #17: Storing malicious such as malware, Iframe distribution, photographs & videos, advertisements, referrer spam and tracking/surveillance code	Defences include detecting embedded malicious code, controlling interaction frequency and enforcement of a single unique action

DS2 Session Storage (Store)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
55	Scraping	Information disclosure	TBD	Open		See OWASP Automated Threat #11: Collecting accessible data and/or processed output from the application	Detect fake or compromised accounts, ensure information is accessible only with authentication and authorisation
56	Skewing	Elevation of privilege	TBD	Open		See OWASP Automated Threat #16: Automated repeated clicking or requesting or submitting content, affecting application based metrics such as counts, and measures of frequency and/or rate	Defences include control of interaction frequency or proper enforcement of a single unique action
57	Spamming	Elevation of privilege	TBD	Open		See OWASP Automated Threat #17: Storing malicious such as malware, Iframe distribution, photographs & videos, advertisements, referrer spam and tracking/surveillance code	Defences include detecting embedded malicious code, controlling interaction frequency and enforcement of a single unique action

DS3 Knowledge Base (Store)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
49	Scraping	Information disclosure	TBD	Open		See OWASP Automated Threat #11: Collecting accessible data and/or processed output from the application	Detect fake or compromised accounts, ensure information is accessible only with authentication and authorisation
50	Skewing	Elevation of privilege	TBD	Open		See OWASP Automated Threat #16: Automated repeated clicking or requesting or submitting content, affecting application based metrics such as counts, and measures of frequency and/or rate	Defences include control of interaction frequency or proper enforcement of a single unique action
51	Spamming	Elevation of privilege	TBD	Open		See OWASP Automated Threat #17: Storing malicious such as malware, Iframe distribution, photographs & videos, advertisements, referrer spam and tracking/surveillance code	Defences include detecting embedded malicious code, controlling interaction frequency and enforcement of a single unique action